

ACME DOIT SECURITY AND IMPACT REPORT

PhishTrainer 2

Internal phishing-awareness training web application for Acme DoIT employees and contractors.

Overall Cybersecurity Risk Rating: LOW

Acme Department of Information Technology
Cyber Security Division

Assessment Date: 2026-04-22

Data Classification: Public//Internal

Deployment Status: Production

1. Executive Summary

1.1 Purpose and Scope

PhishTrainer 2 is an internal-facing web application that delivers interactive phishing-awareness training modules to Acme DoIT employees and contractors. This assessment covers the application layer only — identity, network, endpoint, and platform controls are inherited from the Acme DoIT enterprise stack as documented in Section 7.1.

1.2 Overall Cybersecurity Risk Statement

PhishTrainer 2 presents a **LOW** cybersecurity risk to Acme DoIT. The application processes no regulated data, runs entirely behind enterprise SSO with MFA enforced, stores all training-completion records in the existing Microsoft 365 GCC tenant, and inherits the bulk of its NIST 800-53 control posture from the enterprise environment. Three minor configuration items (HTTP security headers, content-security-policy refinement, and a missing referrer-policy directive) are documented in the POA&M with 30-day remediation targets.

1.3 Asset Summary Table

Field	Value
Asset Name	PhishTrainer 2
Asset Type	Internal web application (training delivery)
Owner	Acme DoIT — Security Awareness Program
Hosting	Microsoft Azure (Gov), Acme DoIT subscription
Authentication	Microsoft Entra ID SSO (MFA enforced)
Data Classification	Public//Internal
Regulated Data	None
Audience	Acme DoIT employees and contractors (~4,200 users)
Recommendation	APPROVED with POA&M — three configuration items (HTTP headers) due 2026-05-22

2. Asset Overview and Capabilities

2.1 Functional Premise

PhishTrainer 2 is a single-page web application that presents users with a sequence of simulated phishing emails, asks them to identify red flags, and tracks completion against an annual training requirement. Completion records are written to a backend SQL database hosted in the Acme DoIT Azure subscription and are surfaced to the Awareness Program team via a Power BI dashboard.

2.3 Key Capabilities

The application delivers eight scenario-based training modules, supports three difficulty levels, generates a per-user completion certificate (PDF), exports completion data via a scheduled CSV to the enterprise GRC platform, and provides an admin console for the Awareness Program team to schedule cohorts and reset completions.

3. Vendor Compliance and Authorization

Not applicable. PhishTrainer 2 is built and operated in-house by the Acme DoIT Security Awareness Program. There is no external vendor under review for this asset.

5. File Sizes, Deployment Analysis, and Infrastructure Impact

Metric	Value
Total source size	412 KB (gzipped: 118 KB)
Frontend lines of code	6,200
Backend lines of code	4,800
Estimated bandwidth per user session	~340 KB (initial load), ~20 KB per scenario completion
Authentication load	Entra ID SSO; SAML assertion at session start; no token refresh during session
Network egress	None outside Acme DoIT Azure subscription; CSV export to internal GRC platform via private endpoint
Endpoint impact	Browser-only; no client install; no impact on Microsoft Intune-managed device baseline

Metric	Value
EDR coverage	N/A on the asset itself; CrowdStrike Falcon coverage on the underlying Windows servers hosting the App Service

6. Data Security and Privacy Assessment

6.1 Developer Attestation

The Awareness Program team attests that PhishTrainer 2 does not collect, store, or transmit any FTI, SSA, CJIS, PHI, or other regulated data category as defined in Appendix A of the Security Impact Report instructions. The only personal data processed is the user's Entra ID UPN, display name, and completion status.

6.3 Regulated Data Framework Assessment

Framework	Applicable	Notes
FTI (IRS Pub 1075)	No	No tax data collected or processed
SSA / CMS (MARS-E)	No	No SSA or CMS data collected or processed
CJIS	No	No criminal-justice information
HIPAA	No	No protected health information
PCI DSS	No	No cardholder data
FERPA	No	No education records
Jurisdictional Privacy Law	No	No personal information beyond UPN/display name; covered by employee notice

6.6 Overall Data Classification and Recommendation

Final classification: **Public//Internal**. Watermark on all generated certificates: "Acme DoIT — Internal Use Only." Dissemination: internal employees and contractors only via Entra ID SSO; no external sharing.

7. NIST 800-53 Rev 5 Controls Assessment

7.1 Scope and Inherited Controls

Control Family	Inherited From	Acme DoIT Policy / Standard	Basis
AC — Access Control	SharePoint Online / Microsoft 365 GCC	POL-AC-001	Role-based access via Entra ID groups; no external/guest users
AT — Awareness and Training	Enterprise security training program	POL-AT-001	This asset is part of the training program
AU — Audit and Accountability	Microsoft Purview / Acme DoIT SOC	POL-AU-001 / STD-SOC-001	Platform logging; SOC 24x7 monitoring
CA — Assessment, Authorization, Monitoring	Acme DoIT GRC program	POL-RA-001 / STD-SOC-001	Continuous monitoring program
CM — Configuration Management	Enterprise change-management process	POL-CM-001	Change control via Azure DevOps pipeline
CP — Contingency Planning	Enterprise BCP/DR program	POL-CP-001	Geo-redundant Azure SQL backups
IA — Identification and Authentication	Microsoft Entra ID	POL-IA-001	Enterprise IAM; MFA per VSE-2024
IR — Incident Response	Acme DoIT SOC / IR team	POL-IR-001	Enterprise IR plan
MP — Media Protection	DLP / Microsoft Purview	POL-DATA-001	Enterprise media classification
PE — Physical and Environmental	Microsoft Azure (Gov) infrastructure	POL-CP-001	Azure data-center controls
PS — Personnel Security	HR / Acme DoIT	POL-IA-001	Personnel vetting and offboarding

7.2 Application-Layer Controls (selected highlights)

Ctrl	Title	Status	Evidence
CM-2	Baseline Configuration	Implemented	SBOM in <code>/docs/sbom.spdx.json</code> ; reviewed 2026-04-15
CM-6	Configuration Settings	Configuration Required	Missing CSP <code>frame-ancestors</code> , missing <code>Referrer-Policy</code> , missing <code>X-Content-Type-Options</code> . See POA&M.
RA-2		Implemented	

Ctrl	Title	Status	Evidence
	Security Categorization		Public//Internal per Section 6.6
SA-8	Security Engineering Principles	Implemented	No <code>eval()</code> , <code>'use strict'</code> enforced, parameterized queries throughout backend
SC-13	Cryptographic Protection	Implemented	TLS 1.3 enforced; FIPS-validated cipher suites (Azure App Service default)

8. WCAG Accessibility Compliance

PhishTrainer 2 is constituent-facing within the meaning of Acme DoIT's accessibility policy and is assessed against **WCAG 2.1 Level AA**. Two findings:

- **1.4.3 Contrast (Minimum):** Two button states (`disabled` and `pending-completion`) use a foreground/background contrast ratio of 3.8:1 against a 4.5:1 minimum. Remediation: adjust the disabled-state palette in the next sprint.
- **2.4.7 Focus Visible:** The keyboard focus indicator on the scenario-card components is removed by a CSS reset. Remediation: restore default focus ring or supply a custom one with $\geq 3:1$ contrast.

Both findings are tracked in the POA&M with 30-day targets.

8.6 Plan of Action and Milestones (POA&M)

ID	Control	Risk Statement	Severity	Remediation	Target	Procurement Action	Owner
POAM-001	CM-6 Configuration Settings	Missing CSP <code>frame-ancestors</code> directive permits clickjacking against the training UI. Impact is limited because the app is internal-only behind SSO, but the gap	Medium	Add <code>Content-Security-Policy: frame-ancestors 'none'</code> to all responses.	30 days (2026-05-22)	No	Awareness Program engineering

ID	Control	Risk Statement	Severity	Remediation	Target	Procurement Action	Owner
		should be closed.					
POAM-002	CM-6 Configuration Settings	Missing X-Content-Type-Options: nosniff allows MIME-type confusion on browsers that ignore declared content types.	Medium	Add header to all responses.	30 days (2026-05-22)	No	Awareness Program engineering
POAM-003	CM-6 Configuration Settings	Missing Referrer-Policy allows leak of internal URL paths to external CDNs serving fonts.	Low	Add Referrer-Policy: no-referrer-when-downgrade to all responses.	30 days (2026-05-22)	No	Awareness Program engineering
POAM-004	WCAG 1.4.3	Disabled-state and pending-completion button colors do not meet AA contrast minimums, blocking some users with low vision from understanding state.	Low	Adjust palette in next UI sprint.	60 days (2026-06-21)	No	Awareness Program engineering
POAM-005	WCAG 2.4.7	Removed focus indicator blocks keyboard-only navigation, a Section 508 /	Medium	Restore focus indicator with ≥3:1 contrast.	30 days (2026-05-22)	No	Awareness Program engineering

ID	Control	Risk Statement	Severity	Remediation	Target	Procurement Action	Owner
		ADA Title II compliance gap.					

The POA&M should be reviewed by the Cyber Security Division on the next regular cadence. Closure of all HIGH and CRITICAL entries is required before the asset can be reclassified to a lower risk rating. None of the entries above are HIGH or CRITICAL.

9. Appendix

9.2 Project Resource Usage and Cost Analysis

Phase	Hours	Method	Cost
Manual review by FTE	6.0	Senior security analyst @ blended rate	\$720
AI-assisted analysis (this report)	—	Claude API; 4 conversation turns	~\$2.80
Total	6.0		~\$723

The AI-assisted analysis represents <1% of total cost and saved an estimated 4–6 additional analyst hours that would have been spent on document drafting, control-mapping, and POA&M formatting.

9.3 Sensitive Data Gate Session Log

```
SIR Sensitive Data Gate – Session Log
=====
Entry 1
Timestamp:          2026-04-22 14:08 ET
Detection:           No regulated data detected (confidence 99%)
Trigger:             Routine application review (no upload of regulated content)
Confidence level:    N/A (no detection)
Authorization required: No
User attestation:    Not required
Authorization file:   N/A
Outcome:             Proceed without restriction
```

9.4 Change History

Version	Date	Author	Change
1.0	2026-04-22	Awareness Program engineering	Initial assessment

Acme DoIT Security and Impact Report — PhishTrainer 2
Acme Department of Information Technology — Cyber Security Division
Assessment Date: 2026-04-22